

Projeto de Gestão de Riscos

Baseado em ISO 27005



Ágata Czkut

Introdução:

Este projeto tem como objetivo aplicar, na prática, conceitos de Gestão de Riscos em Segurança da Informação com base na ISO 27005.

A iniciativa busca simular um cenário real de análise de riscos, permitindo a identificação, avaliação e tratamento de ameaças que podem impactar ativos organizacionais.

Além disso, o projeto visa consolidar conhecimentos na área de Governança, Riscos e Compliance (GRC), aproximando a teoria da prática.

Escopo:

O cenário analisado consiste em uma empresa fictícia do segmento de e-commerce responsável pela comercialização de produtos por meio de uma plataforma digital.

O ambiente inclui um site de vendas, um banco de dados com informações de clientes e pedidos, além de um sistema de pagamento integrado.

A análise de riscos será conduzida considerando os principais ativos envolvidos nesse contexto.

1- Identificação de Ativos:

Considerado o contexto de e-commerce definido anteriormente, foram mapeados os principais ativos envolvidos na operação.

- **Plataforma web (site de vendas):** responsável pela interface com o cliente e pela realização das transações comerciais.
- **Banco de dados:** armazena informações de clientes, pedidos e histórico de compras.
- **Dados de clientes:** incluem informações pessoais, como nome, e-mail e endereço, sendo considerados ativos críticos sob a ótica da confidencialidade.
- **Sistema de pagamento:** responsável pelo processamento das transações financeiras e integração com serviços externos.

A identificação desses ativos é fundamental para a análise de riscos, uma vez que permite compreender quais elementos possuem maior valor para o negócio e consequentemente, demandam maior nível de proteção.

Para melhor compreensão do valor dos ativos, foi realizada a classificação com base nos princípios de Confidencialidade, Integridade e Disponibilidade (CIA).

Ativo	Confidencialidade	Integridade	Disponibilidade
Dados de clientes	Alta	Alta	Média
Banco de dados	Média	Alta	Alta
Site	Baixa	Média	Alta
Sistema pagamento	Alta	Alta	Alta

2- Identificação de Ameaças:

Essa etapa tem como foco a identificação das principais ameaças capazes de impactar os ativos previamente mapeados.

Com base no contexto do ambiente de e-commerce, foram consideradas ameaças relevantes que podem comprometer a segurança da informação e a continuidade do negócio:

- **Ataques de negação de serviço (DDoS):** podem tornar a plataforma indisponível, impactando diretamente as operações de venda.
- **Vazamento de dados:** exposição indevida de informações sensíveis de clientes, com possíveis implicações legais e reputacionais.
- **Ataques de phishing:** tentativa de obtenção de credenciais por meio de engenharia social, comprometendo acessos legítimos.
- **Infecção por malware:** pode resultar em indisponibilidade de sistemas, sequestro de dados ou acesso não autorizado.
- **Erros humanos:** ações não intencionais que podem levar à exclusão, alteração ou exposição indevida de informações.

A identificação dessas ameaças permite antecipar possíveis cenários de risco e direcionar a análise para os impactos que podem afetar os ativos críticos da organização.



Classificação das Ameaças por Origem

Externas:

- DDoS
- Malware
- Phishing

Internas:

- Erro humano

3- Identificação de Vulnerabilidades:

Essa etapa tem como objetivo identificar as principais vulnerabilidades presentes no ambiente analisado.

As vulnerabilidades representam fragilidades que podem ser exploradas por ameaças, potencializando a ocorrência de incidentes de segurança da informação.

Considerando o contexto do e-commerce, foram identificadas as seguintes vulnerabilidades:

- **Uso de senhas fracas:** aumenta o risco de acessos não autorizados aos sistemas.
- **Ausência de autenticação multifator (MFA):** facilita a exploração de credenciais comprometidas.
- **Sistemas desatualizados:** podem conter falhas conhecidas e exploradas por atacantes.
- **Falta de criptografia de dados sensíveis:** eleva o risco de exposição em caso de vazamento.
- **Ausência de políticas de backup adequadas:** pode comprometer a recuperação de dados em incidentes.
- **Controle de acesso inadequado:** permissões excessivas podem permitir acessos indevidos a informações críticas.

A identificação dessas vulnerabilidades é essencial para compreender como as ameaças previamente mapeadas podem se concretizar, permitindo uma visão mais clara dos cenários de risco.

Exemplos de vulnerabilidades críticas

- Falta de MFA
- Ausência de criptografia
- Sistemas desatualizados

4- Análise de Riscos:

Esta etapa analisa os riscos identificados, considerando a probabilidade de ocorrência e o impacto potencial para o negócio.

A análise foi realizada a partir da correlação entre ativos, ameaças e vulnerabilidades previamente mapeados, permitindo a construção de cenários de risco mais realistas.

Para a classificação dos riscos, foram considerados os seguintes critérios:

- **Impacto:** nível de dano causado ao negócio (Baixo, Médio, Alto)
- **Probabilidade:** chance de ocorrência do risco (Baixa, Média, Alta)

Com base nesses critérios, foi possível priorizar os riscos mais críticos e direcionar ações de tratamento mais assertivas.

Os riscos classificados como críticos e altos foram priorizados para tratamento imediato, visando reduzir impactos significativos ao negócio.

ID	Ativo	Ameaça	Vulnerabilidade	Impacto	Probabilidade	Nível de Risco
R1	Dados de clientes	Vazamento	Falta de criptografia	Alto	Alto	Crítico
R2	Site	DDoS	Ausência de proteção (WAF)	Médio	Alto	Alto
R3	Banco de dados	Malware	Sistema desatualizado	Alto	Médio	Alto
R4	Sistema pagamento	Phishing	Sem MFA	Alto	Médio	Alto
R5	Banco de dados	Erro humano	Falta de controle de acesso	Médio	Médio	Médio

5- Tratamento de Riscos:

Esta etapa tem o objetivo definir estratégias de tratamento para riscos previamente analisados.

O tratamento de riscos consiste na seleção e implementação de medidas que visam reduzir a probabilidade de ocorrência ou o impacto dos riscos identificados, alinhando-se às boas práticas de Governança, Riscos e Compliance (GRC).

Para cada risco, foram consideradas as seguintes estratégias:

- **Mitigar:** implementação de controles para reduzir o risco
- **Aceitar:** quando o risco está dentro do nível aceitável
- **Transferir:** compartilhamento do risco com terceiros (ex: seguros, provedores)
- **Evitar:** eliminação da atividade que gera o risco

Com base na análise realizada, foram definidas ações de tratamento priorizando os riscos classificados como críticos e altos, garantindo maior efetividade na proteção dos ativos organizacionais.

Essa etapa reforça a importância de uma abordagem estruturada e orientada à tomada de decisão, permitindo que a organização atue de forma proativa na gestão de riscos.

ID	Risco	Nível	Tratamento	Ação de Controle	Prioridade
R1	Vazamento de dados	Crítico	Mitigar	Criptografia + Controle de acesso + MFA	Alta
R2	Indisponibilidade (DDoS)	Alto	Mitigar	Implementação de WAF e CDN	Alta
R3	Infecção por malware	Alto	Mitigar	Antivírus + Atualizações regulares	Média
R4	Comprometimento por phishing	Alto	Mitigar	Treinamento de usuários + MFA	Média
R5	Erro humano	Médio	Mitigar	Política de acesso + revisão de permissões	Baixa

Recomenda-se o monitoramento contínuo dos riscos e controles implementados, garantindo a melhoria contínua do processo.

Conclusão:

A realização desse laboratório prático permitiu a aplicação dos conceitos de Gestão de Riscos em um cenário simulado de e-commerce, evidenciando a importância de uma abordagem estruturada na identificação, análise e tratamento de riscos.

Ao longo do projeto, foi possível mapear ativos críticos, identificar ameaças e vulnerabilidade relevantes, além de avaliar os riscos com base em impacto e probabilidade, permitindo uma priorização eficiente das ações de tratamento.

A definição de controles e estratégias de mitigação reforça o papel da área de Governança, Riscos e Compliance (GRC) como um elemento essencial para a proteção dos ativos organizacionais e para a continuidade de negócios.

Este projeto demonstra, na prática, como a gestão de riscos contribui para a tomada de decisão estratégica, fortalecendo a segurança da informação e agregando valor ao negócio.

Por fim, destaca-se a importância do monitoramento contínuo e da melhoria dos processos, garantindo a evolução constante da maturidade em segurança e gestão de riscos.

Este laboratório representa um passo importante no desenvolvimento prático na área de GRC.